

① Topic 1: Footprinting Tools - Conducting Competitive Intelligence

Scenario :

A cybersecurity consultant is performing a passive security assessment on ABC Technologies. The goal is to collect only publicly available information without directly interacting with the company's servers

Information Required	Footprinting Tool	How the tool is used	Competitive Intelligence obtained
Domain Registration Details	WHOIS	Performs a WHOIS lookup on the company's domain	Reveals domain owner, register, registration date, expiry date, name servers and administrative contacts.
Employee Email Addresses	theHarvester	Searches public sources such as Google, LinkedIn	Collects employee email addresses, hostnames, employee names
Technology Stack	Wappalyscr	Analyses the company's public website	Identifies web servers, CMS, programming language, Javascript libraries, CDN, framework
Publicly Exposed Subdomains	Sublist3r	Searches search engine, SSL certificate, DNS records	Discovers public sub-domains such as mail, vpn, dev, test.

Explanation of Each Tool :-

1. WHOIS

1) Retrieves domain registration information

2) Shows:

1) Domain owner

2) Register

3) Name Servers

4) Creation and expiration dates

Ex:- whois abctechnologies.com

Benefit:-

1) Identifies ownership and DNS infrastructure

2) Detects recently registered or expiring domains

2. theHarvester

1) Performs passive OSINT searches

2) Collects :

- Employee email addresses

- Hostnames

Ex:- theHarvester -d abctechnologies.com -b google

Benefit:-

1) Maps employee contact information

2) Helps understand organizational structure

3. Wappalyzer

- 1) Browser extension/Web tool
- 2) Detects technologies used by the website

Ex:- Apache/Nginx, PHP, React

Benefit:-

- 1) Identifies software technologies
- 2) Helps understand possible software version

4. Sublist3r

Discovers publicly available subdomains

Ex:-

Sublist3r -d abctechnologies.com

Possible output:-

mail.abctechnologies.com

vpn.abctechnologies.com

api.abctechnologies.com

② Topic 2 :- DNS Zone Transfers

Scenario:-

During an authorized penetration test, a security analyst suspects that the target's organization main server DNS server is misconfigured and allows unauthorized DNS zone transfers.

② Task: Verify DNS zone Transfer

Scenario:-

During an authorised action, the analyst can use the dig command to check whether DNS server permits a zone transfer

Command:-

```
dig AXFR @ns1.targetdomain.com  
targetdomain.com
```

Expected Result:-

- * If the transfer is denied: The DNS server is properly configured, and no records are disclosed
- * If the transfer succeeds: The DNS server returns all DNS records stored in the zone, indicating a security misconfiguration

Information Retrieved from a Successful zone Transfer :-

A successful DNS zone transfer may reveal:

A Records: IP addresses of the web servers, application servers, and other hosts

MX Records: Mail servers responsible for handling the organization's email

NS Records: Authoritative DNS servers for the domain

CNAME Records: Alias names pointing to other hosts or services

Sub domains :- Public and sometimes internal subdomains
Such as mail, vpn, dev, test, api

Conclusion :-

DNS zone transfers are intended only for synchronization between primary and secondary DNS servers. If authorized zone transfers are allowed, they can expose valuable DNS information that assists in reconnaissance. Therefore organizations should properly configure DNS servers to restrict zone transfers and protect sensitive network information.

③ Task: Introduction to Social Engineering- Social Engineering Attacks and Countermeasures

Scenario:

Employees of an organization receive an email claiming to be from the IT department asking them to verify their login credentials through a provided link due to an urgent security update

Types of Social Engineering Attack

This is a phishing Attack

A phishing attack is a type of Social engineering attack in which attackers impersonate a trusted organisation or person to trick users into revealing sensitive information like username, passwords or banking details. The attacker creates a sense of urgency so that employees act without verifying the email's authenticity.

Countermeasures:-

- 1) Verify the sender email address instead of trusting the display name
- 2) Do not click on suspicious links or download unexpected attachments
- 3) Hover over the link to check whether the URL belongs to the organisation official website
- 4) Contact the IT department directly through unsolicited emails
- 5) Never enter login credentials on websites accessed through official communication confirm request
- 6) Enable Multi Factor Authentication to provide an extra layer of security even if credentials are compromised
- 7) Attend regular security awareness training

Conclusion:-

The email described in the scenario is a phishing attack. By verifying the sender, avoiding suspicious links, confirming requests with IT department, reporting suspicious emails and using Multi Factor Authentication, employees can effectively prevent credential theft and protect organisation's information system.